



المدرسة الوطنية للعلوم التطبيقية - بني ملال

ⵜⴰⵎⴰⵔⵜ ⵜⴰⵎⴰⵏⴰⵢⵜ ⵜⴰⵔⴰⵎⴰⵏⵜ ⵜⴰⵔⴰⵎⴰⵏⵜ - ⵎⴰⵎⴰⵏⴰⵢⵜ ⵜⴰⵎⴰⵏⴰⵢⵜ

Ecole Nationale des Sciences Appliquées - Béni Mellal

NATIONAL SCHOOL OF APPLIED SCIENCES OF BENI MELLAL

Sultan Moulay Slimane University | Program: AI & Cybersecurity

LEGAL ANALYSIS DOCUMENT

Design of a Responsible AI System Compliant with GDPR

Written by

AGOURRAM Hajar BOUARAFA Sara

Supervisor

Pr. TOUIL

Module: Ethics and Digital Law

Academic Year: 2025-2026

1. Introduction and Context

This document constitutes the legal and regulatory analysis of the project to deploy an artificial intelligence (AI) system at ENSA Béni Mellal. This system aims to generate automated content, assist academic decision-making, and process non-sensitive data, within the framework of the Ethics and Digital Law module.

The analysis covers: the application of GDPR principles, the identification of legal bases, the guarantee of individuals' rights, the conduct of a DPIA, and the definition of an ethical and responsible governance framework.

2. Legal Analysis: GDPR Framework

2.1 Data Controller

In accordance with Articles 4 and 7 of the GDPR, the data controller is the entity that determines the purposes and means of processing. In this project:

Element	Detail
Data Controller	ENSA Béni Mellal
Legal Representative	The Director of ENSA Béni Mellal
Purpose of Processing	Academic assistance, content generation, academic decision support
Data Processed	Internal identifiers, request history, anonymized activity logs

2.2 Legal Basis for Processing (Art. 6 GDPR)

The primary legal basis retained is Article 6.1.e of the GDPR (public interest mission), ENSA being a public higher education institution. Consent (Art. 6.1.a) is collected on a complementary basis at first use.

Legal Basis	Applicability	Justification
Art. 6.1.e – Public interest mission	Primary	Public educational mission of ENSA
Art. 6.1.a – Consent	Complementary	Collected at first login
Art. 6.1.f – Legitimate interest	Secondary	Improvement of educational services to be documented

2.3 Fundamental Principles (Art. 5 GDPR)

Principle	Application to the system	Concrete measure
Lawfulness	Documented legal basis Art. 6.1.e	Processing activities register kept up to date
Minimisation	Collection limited to what is strictly necessary	Technical prohibition on entering personal data
Purpose Limitation	Exclusively educational use	Binding usage policy, access control

Storage Limitation	Maximum retention period defined	Auto-purge logs 12 months; history 2 years
Integrity & Security	Technical and organisational measures	Authentication, encryption, logging
Accountability	Documented accountability	DPIA, designated DPO, annual audit

3. Rights of Data Subjects

Right (GDPR)	Exercise modality	Deadline	Article
Right to information	Notice displayed before any use	Immediate	Art. 13-14
Right of access	Written request to DPO or dedicated portal	1 month	Art. 15
Right to rectification	Correction form for inaccurate data	1 month	Art. 16
Right to erasure	Deletion on request, without contrary legal obligation	1 month	Art. 17
Right to object	Immediate cessation of processing upon request	Immediate	Art. 21
Right to portability	CSV/JSON export of data on request	1 month	Art. 20
No automated decision-making	Mandatory human validation for impactful decisions	Systematic	Art. 22

3.1 Right Not to Be Subject to a Solely Automated Decision (Art. 22 GDPR)

Article 22 of the GDPR applies only when the automated decision produces a legal effect or significantly affects the person. The system therefore distinguishes two application regimes:

Regime 1 | Simple assistance responses (Art. 22 not applicable)

Responses to general queries (summaries, explanations, educational questions) are transmitted directly to the user. They produce no legal effect or significant impact. A mandatory warning reminds the user of the automatic nature of the response and invites them to exercise critical thinking. Responsibility for use lies with the end user.

Regime 2 | Decisions with academic impact (Art. 22 fully applicable)

Any decision likely to significantly affect a student (evaluation, guidance, result) must imperatively follow the validation circuit below, BEFORE any communication to the data subject:

Step	Action	Actor	Traceability
1	AI system generates a suggestion	Automatic system	Timestamped log recorded

2	Validation / modification / rejection	MANDATORY authorised human supervisor	Identity + date recorded
3	Communication of the final decision	Human supervisor	Final decision archived

4. Impact Assessment (DPIA – Art. 35 GDPR)

4.1 Necessity of a DPIA

In accordance with Article 35 GDPR and the WP248 guidelines of the G29, a DPIA is mandatory when at least two EDPB criteria are met. The ENSA AI system meets the following criteria:

EDPB Criterion	Present?	Justification
Automated processing / systematic evaluation	YES	Automatic response generation on user queries
Large-scale processing	POTENTIAL	Several hundred potential internal users
Systematic monitoring	NO	Logging for audit purposes only
Sensitive data (Art. 9 GDPR)	NO	Total technical and procedural prohibition
Impactful automated decision	MODERATE	Decision assistance and mandatory human oversight

Conclusion: DPIA MANDATORY before any deployment (2 EDPB criteria met: WP248 rule)

4.2 Risks and Mitigation Measures

Risk	Probability	Severity	Mitigation measure
Algorithmic bias / discrimination	Medium	High	Human oversight, periodic system review
Hallucinations / AI errors	High	Medium	Systematic warning, mandatory human validation
Data breach	Low	High	AES-256 encryption, security audit, incident plan
Privacy infringement	Low	High	Automatic sensitive data filtering, entry prohibition
Excessive data retention	Medium	Medium	Documented retention policy, automatic purge
Excessive reliance on AI	High	Medium	User training, warnings, documented limits

5. Ethical Governance of the AI System

5.1 Actors and Responsibilities

Actor	Role	GDPR Obligations	AI Responsibility
Data Controller (ENSA)	Defines purposes and means of processing	Art. 5, 24, 25, 30, 35	Global accountability
Processor (Host)	Technical infrastructure and hosting	Art. 28 – Mandatory contract	Technical data security
DPO – Data Protection Officer	Legal advice, compliance control, CNDP liaison	Art. 37-39 GDPR	AI compliance audit, DPIA management
End User (Students/Staff)	Uses the system per the usage policy	Subject of rights Art. 13-22	Responsibility for submitted queries

5.2 Human Oversight and Transparency

- Mandatory human validation for any impactful academic decision before communication to the user (Art. 22 GDPR);
- Contestation procedure open to any user, handled within 5 working days;
- Complete traceability: each interaction is logged with timestamp and pseudonymised identifier;
- Prior information: explicit notice indicating AI use before any interaction;
- Systematic warning on each response reminding its automatic nature and limitations;
- Quarterly review by the AI supervision committee to detect potential drift.

6. Technical Compliance Requirements (Art. 32 GDPR)

Component	Technology (Open Source)	GDPR/Security Justification
Backend	Python 3.x + Flask	Open source, full code control, no third-party transfers
Database	SQLite / PostgreSQL	Local storage, full control, no transfer outside ENSA
Interface	HTML5/CSS3 – Jinja2 Templates	No external CDN dependency carrying trackers
Authentication	Flask sessions + bcrypt hashing	Art. 32 – Security of authentication data
Logging	Python logging module + timestamped SQLite	Access traceability, Art. 5.2 GDPR compliance

Additional security measures include: automatic sensitive data filtering on input, TLS 1.3 encryption in transit, restricted system permissions on the database, and CSRF protection via tokens.

7. Definition of Compliance

The AI system is considered compliant with the applicable legal and ethical framework if and only if all of the following criteria are met:

Compliance Criterion	Regulatory Reference	Status
Legal bases for processing identified and documented	Art. 6 & 30 GDPR	COMPLIANT
Data subjects' rights guaranteed and exercise facilitated	Art. 12 to 22 GDPR	COMPLIANT
Technical and organisational security measures defined	Art. 25 & 32 GDPR	COMPLIANT
Responsibility clearly assigned to each actor	Art. 24, 28, 37 GDPR	COMPLIANT
Ethical risks identified and mitigation measures defined	Art. 35 GDPR + EDPB Guidelines	COMPLIANT
Human oversight planned and validation before impactful decision	Art. 22 GDPR + EU AI Principles	COMPLIANT
DPIA carried out before deployment	Art. 35 GDPR	COMPLIANT
Processing activities register kept up to date	Art. 30 GDPR	COMPLIANT
Users informed of AI use before interaction	Art. 13 + Transparency principle	COMPLIANT
Sensitive data technically excluded from processing	Art. 9 GDPR	COMPLIANT

The system is declared COMPLIANT: all criteria of the Definition of Compliance are met.

8. Conclusion

This analysis demonstrates that the deployment of the AI system at ENSA Béni Mellal can be carried out in full compliance with the GDPR and the ethical principles of AI, subject to the rigorous implementation of the identified measures. The key points are:

- Solid legal basis founded on Art. 6.1.e (public interest mission), supplemented by explicit consent;
- Six fundamental principles of Art. 5 GDPR operationalised by concrete documented measures;
- Data subjects' rights guaranteed by accessible exercise mechanisms within regulatory deadlines;
- Mandatory DPIA conducted before any deployment, with adequate risk mitigation measures;
- Two distinct regimes for Art. 22: simple responses transmitted with warning, impactful decisions subject to mandatory human validation BEFORE communication;
- Clear governance architecture with four identified actors and defined responsibilities;
- Criteria of the Definition of Compliance fully met.

9. Regulatory References

- Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 (GDPR);
- EDPB/G29 Guidelines on DPIA – WP248;
- Ethics Guidelines for Trustworthy AI, European Commission, 2019;
- Proposal for a Regulation on Artificial Intelligence (AI Act), European Commission, 2021;
- Recommendation CM/Rec(2020)1 of the Committee of Ministers of the Council of Europe;
- Guidelines 05/2020 of the EDPB on consent (Art. 6.1.a GDPR).